Modelo de Responsabilidade Compartilhada na Prática

Guia operacional de segurança em nuvem (IaaS, PaaS, SaaS)

Documento de Referência e Governança Operacional

Gemini Notebook



O Paradigma (Não é de quem é a culpa)

- Provedor protege a infraestrutura física e serviços gerenciados.
- Cliente protege dados, identidades e configurações.
- **Foco operacional:** Quem executa, aprova, monitora e comprova?



Divisão Arquitetural (IaaS, PaaS, SaaS)

- **IaaS:** Cliente gerencia SO, rede virtual e aplicações. Provedor manage fysical hardware.
- **PaaS:** Provedor gerencia runtime; Cliente gerencia código e dados.
- **SaaS:** Provedor gerencia software; Cliente gerencia acessos e políticas.



Ecossistema de Operação (Papéis)

- **SecInfo:** Requisitos, monitoramento e resposta.
- **Cloud Ops:** Redes, backups e infraestrutura.
- **DevSecOps:** Código seguro e pipelines.
- **Negócio / Jurídico:** Classificação, riscos e contratos.



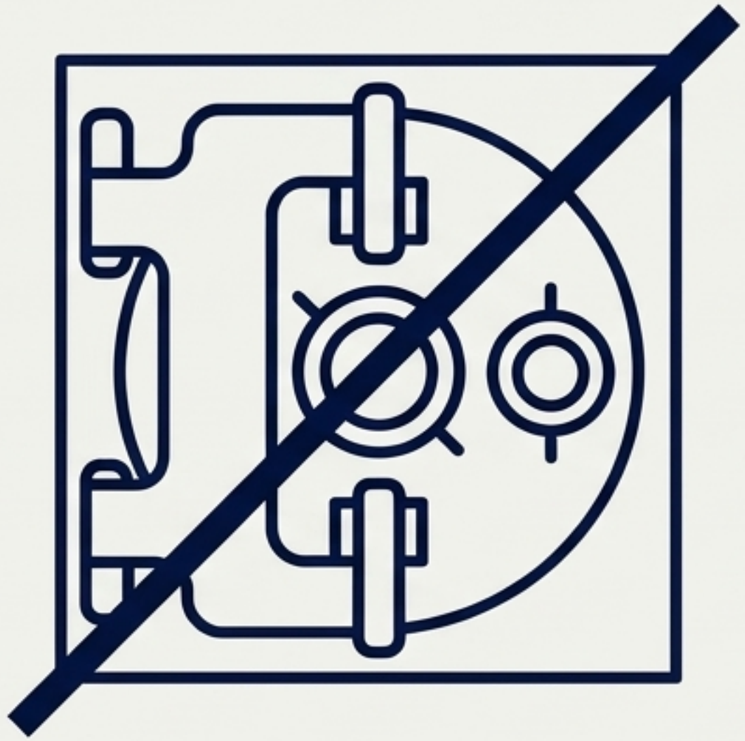
Governança e Resposta a Incidentes

- **Rotina:** Classificar, mapear, implantar padrões, operar e auditar.
- **Incidentes:** Separar fatos de hipóteses, isolar impacto e preservar evidências.
- **Checklist:** IAM/MFA, auditoria contínua, RPO/RTO testados.

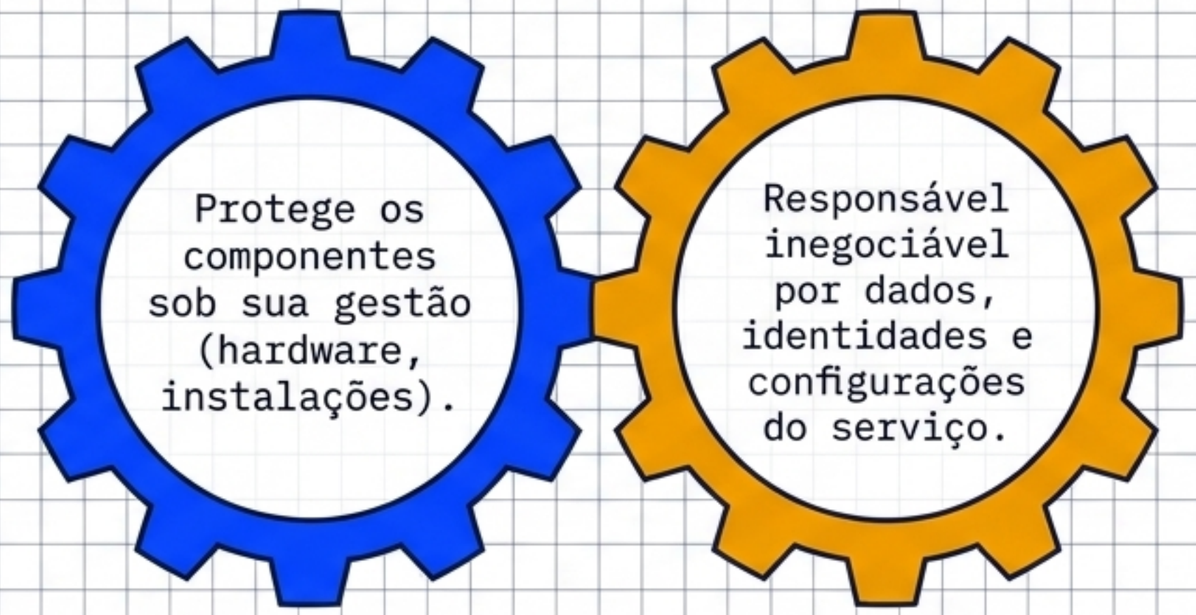
Gemini Notebook

O Mito

Contratei a nuvem, estou seguro.



A Realidade Operacional



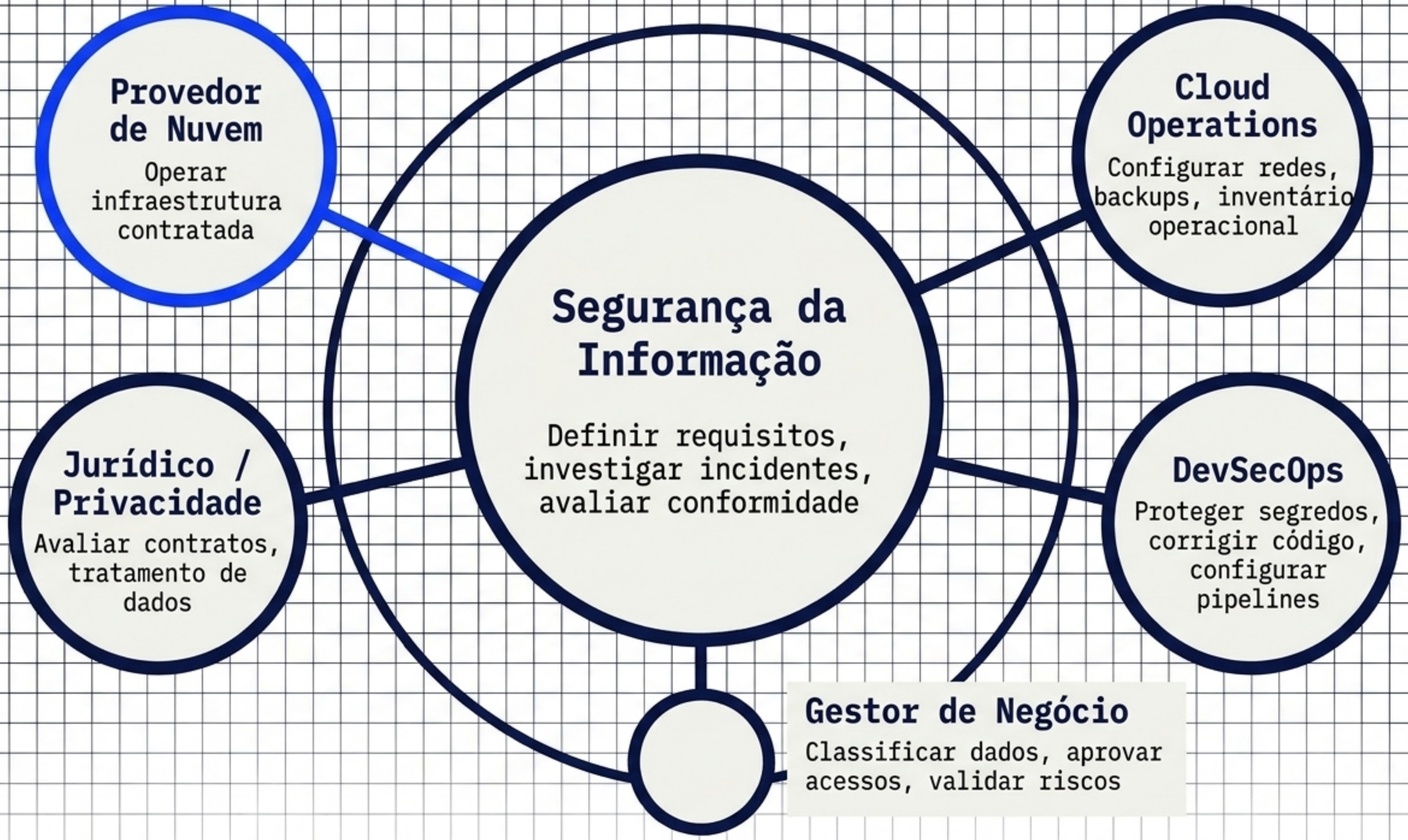
A Pergunta Crítica:
Não é de quem é a culpa, mas sim:
Quem deve executar, aprovar, monitorar e comprovar cada controle?

Gemini Notebook

	IaaS	PaaS	SaaS
Configuração de segurança do serviço	Configuração de segurança do serviço	Configuração de segurança do serviço	Configuração de segurança do serviço
Usuários, permissões e dados	Usuários, permissões e dados Cliente com controles do provedor	Usuários, permissões e dados Cliente com controles do provedor	Usuários, permissões e dados Cliente com controles do provedor
Código da aplicação	Código da aplicação	Código da aplicação	Código da aplicação
Runtime / plataforma gerenciada	Runtime / plataforma gerenciada	Runtime / plataforma gerenciada	
Sistema operacional do servidor	Sistema operacional do servidor	Sistema operacional do servidor	
Instalações, hardware, infraestrutura física	Instalações, hardware, infraestrutura física	Instalações, hardware, infraestrutura física	

Atenção: Serviços gerenciados têm particularidades. Sempre consulte a matriz de responsabilidades do serviço específico.

Gemini Notebook



Gemini Notebook



1. Classificar

Identificar modelo (IaaS/PaaS/SaaS) e componentes gerenciados.

2. Mapear

Identificar dados sensíveis, requisitos e regiões.

3. Definir

Documentar responsáveis por execução e aprovação.

4. Implantar

Aplicar MFA, menor privilégio, criptografia e logging.

5. Operar

Monitorar eventos, auditar permissões e testar backups.

6. Responder

Isolar impactos, preservar logs e atualizar processos.

Gemini Notebook

MATRIZ DE DIAGNÓSTICO E RESPOSTA A INCIDENTES

Cenário	Causa Raiz (Falha Cliente)	Resposta Imediata	Prevenção
Armazenamento Exposto	Permissões de bucket incorretas.	Restringir acesso, preservar logs, avaliar vazamento.	Bloqueio padrão público, políticas como código.
VM sem Atualização (IaaS)	Falha de *patching* no SO convidado.	Isolar instância, corrigir vulnerabilidade, rotacionar credenciais.	Inventário, varredura de vulnerabilidades, imagens padronizadas.
Segredo no Código (PaaS)	Chave de API publicada em repositório.	Revogar segredo, revisar acessos de terceiros.	Detecção de segredos no CI/CD, cofres de senhas.

Gemini Notebook

MATRIZ DE DIAGNÓSTICO E RESPOSTA A INCIDENTES

Cenário	Causa Raiz (Falha Cliente)	Resposta Imediata	Prevenção
Admin Comprometido (SaaS)	Reutilização de senha, ausência de MFA.	Bloquear sessões, redefinir credenciais, analisar logs de compartilhamento.	SSO com MFA, contas separadas.
Falha de Restauração	Backup configurado, mas RPO/RTO e retenção nunca testados.	Medir perdas, recuperar o possível.	Testes de desastre periódicos.
Vazamento CI/CD	Credenciais permanentes com permissão excessiva.	Revogar credencial estática, reverter alterações.	Menor privilégio, autenticação de workload.
Queda do Provedor	Arquitetura sem redundância para indisponibilidade regional.	Acionar plano de continuidade (failover).	Arquitetura resiliente, análise de SLA.

Gemini Notebook

DASHBOARD DE VALIDAÇÃO DE CONTROLES DE SEGURANÇA

Controle / Requisito de Segurança	Responsável	Evidência de Conformidade / Validação
MFA para administradores	Cliente	Política de identidade / Relatório de adesão
Atualização do SO em VM IaaS	Cliente	Inventário e registros de patch
Segurança física do datacenter	Provedor	Relatórios e certificações contratuais
Políticas de bucket e compartilhamento	Cliente	Configurações e alertas
Proteção da plataforma gerenciada	Provedor	Documentação do serviço e compromissos
Rotação de chaves da aplicação	Cliente	Histórico de rotação e auditoria
Teste de recuperação dos dados	Cliente	Registro de teste e resultados
Correção de código vulnerável	Cliente	Pull requests, testes e versões

Gemini Notebook

ID: INC-2026-014 | **Serviço:** Armazenamento de objetos | **Severidade:** Alta

[FATO OBSERVADO]:
Objeto acessível sem autenticação.

[EVIDÊNCIA]:
Configuração do recurso, alerta do serviço, eventos de acesso.

[HIPÓTESE]: Mudança indevida em política de acesso (nota: nunca presumir culpa antes da investigação).

[IMPACTO]: Exposição potencial de documentos.

[AÇÃO IMEDIATA]: Restringir acesso, preservar evidências.

Responsável:
Cloud Ops

Gemini Notebook

Arquitetura e Identidade

- [ ] Inventário de serviços e responsáveis atualizado.
- [ ] Matriz de **responsabilidade** específica por contrato validada.
- [ ] Políticas de **IAM**, **MFA** e **menor privilégio** implantadas.
- [ ] Gestão de **vulnerabilidades** e **segredos** documentada.
- [ ] Configurações de segurança verificadas continuamente.

Dados e Continuidade

- [ ] Dados classificados e **criptografia** definida.
- [ ] Registros de **auditoria** habilitados e analisados.
- [ ] **Backups** testados conforme requisitos de **RPO** / **RTO**.
- [ ] Plano de resposta a **incidentes** atualizado.
- [ ] Revisões periódicas de **riscos** executadas.

Gemini Notebook

A responsabilidade compartilhada é uma disciplina de governança.

Contratos esclarecem obrigações, a arquitetura define os limites técnicos, as equipes executam controles e as evidências comprovam a gestão. A nuvem não substitui a segurança interna.

NIST SP 800-145 (Definição de Cloud Computing) & NIST CSF 2.0
Matrizes Oficiais: AWS Shared Responsibility, Microsoft Azure, Google Cloud Shared Fate.

Gemini Notebook